# LazySysAdmin – Penetration Testing Report

Manuela Salazar Moscoso.
Estudiante de ciberseguridad

# Resumen Ejecutivo.

Se realizó una evaluación de seguridad sobre LazySysAdmin, una máquina Linux vulnerable utilizada en un entorno de laboratorio controlado, con el propósito de identificar debilidades de configuración y comprobar hasta qué punto podían comprometer la seguridad del sistema.

La práctica se desarrolló desde Kali Linux, aplicando una metodología progresiva de pruebas de penetración que incluyó reconocimiento de red, enumeración de servicios, análisis de información expuesta, validación de credenciales y escalada de privilegios.

**Objetivo**:

Evaluar la seguridad de la máquina e identificar posibles vías de acceso no autorizado.

**Los objetivos específicos:**

- Identificar la máquina objetivo y los servicios expuestos en la red.
- Detectar recursos compartidos y archivos accesibles sin autenticación adecuada.
- Localizar información sensible y posibles credenciales almacenadas de forma insegura.
- Comprobar la validez y posible reutilización de las credenciales encontradas.
- Evaluar los permisos de las cuentas de usuario y las posibilidades de escalada de privilegios.
- Demostrar el impacto que puede tener la combinación de diferentes debilidades de seguridad.

# Resumen Ejecutivo.

**Principales hallazgos**

Durante la evaluación se identificaron varias debilidades que, combinadas, permitieron comprometer completamente la máquina:

1. **Exposición de recursos compartidos:** se encontraron recursos SMB accesibles que permitieron consultar archivos internos.
2. **Almacenamiento inseguro de información:** se localizaron credenciales en archivos de texto y archivos de configuración relacionados con WordPress.
3. **Exposición de credenciales de WordPress:** el archivo wp-config.php contenía información sensible de conexión.
4. **Reutilización de credenciales:** la información obtenida permitió continuar las pruebas de autenticación en otros servicios.
5. **Acceso remoto mediante SSH:** se consiguió acceder al sistema utilizando una cuenta válida.
6. **Privilegios excesivos:** la revisión de permisos mediante sudo -l reveló una configuración que permitió ejecutar acciones administrativas.
7. **Compromiso completo del sistema:** se consiguió acceder al contexto de root y verificar el resultado mediante el archivo proof.txt.

**Resultado de la evaluación**:

Se consiguió elevar los privilegios hasta administrador del sistema (root).

Se demostró que no es necesario explotar una única vulnerabilidad compleja para comprometer un equipo. La combinación de **recursos compartidos expuestos, credenciales almacenadas sin protección adecuada, reutilización de contraseñas y permisos débiles** puede facilitar una cadena de ataque que termine en el control completo del sistema.

**Conclusión ejecutiva:**

El principal problema identificado fue la acumulación de malas prácticas de seguridad y configuraciones permisivas. La falta de protección de información sensible y una gestión inadecuada de los privilegios facilitaron el avance desde el reconocimiento inicial hasta el acceso administrativo.

Aunque la evaluación se realizó en un laboratorio educativo, los hallazgos representan riesgos relevantes para cualquier organización que no aplique controles adecuados sobre sus archivos, credenciales, servicios y cuentas de usuario.

# Reconocimiento y descubrimiento de la máquina

**Objetivo:** identificar los dispositivos activos en la red del laboratorio y localizar la dirección IP de la máquina LazySysAdmin.

1. netdiscover

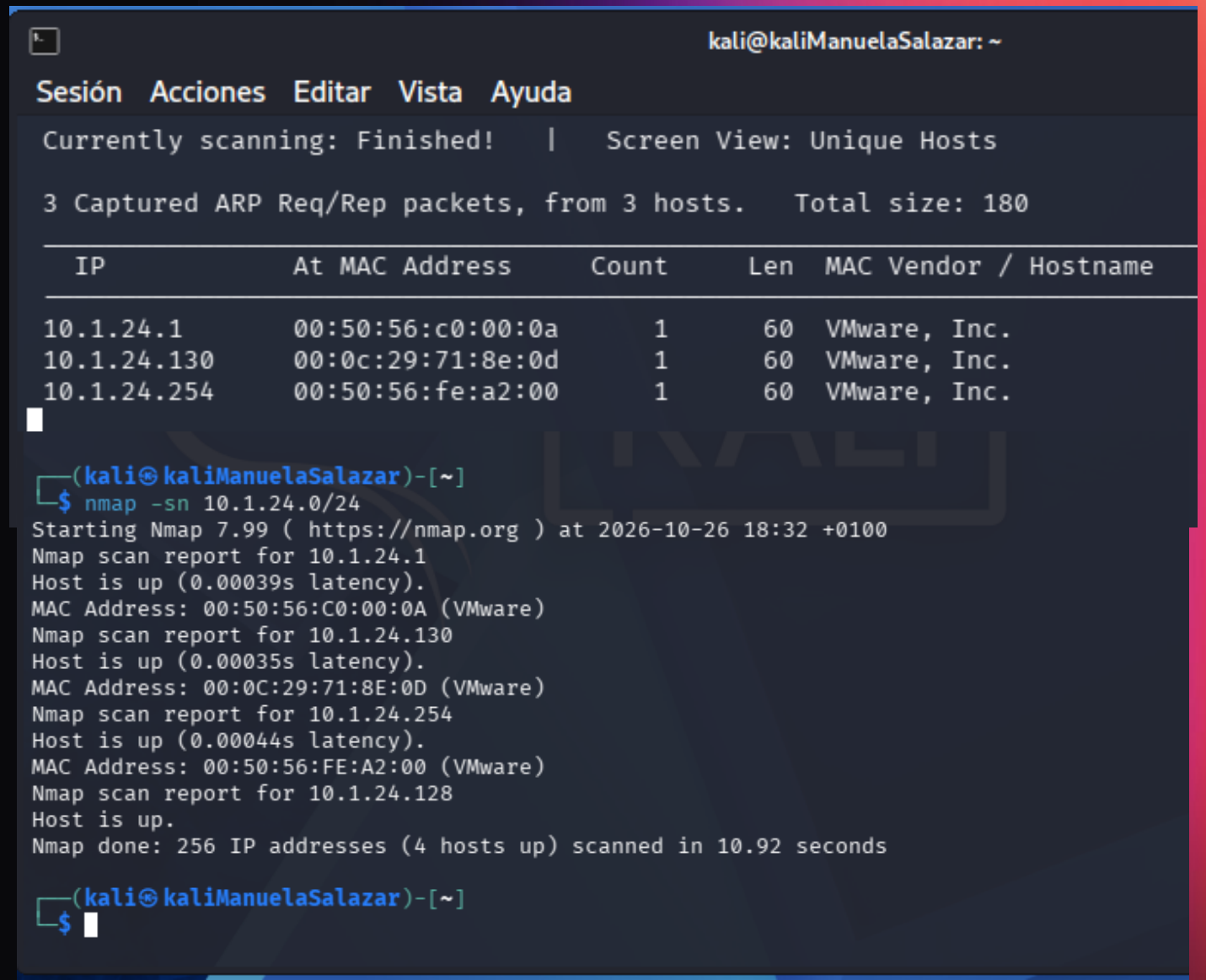
2. nmap:

Realizamos un primer escaneo para comprobar qué equipos estaban activos.

-sn permite realizar descubrimiento de hosts sin efectuar un escaneo de puertos.

-PR realiza descubrimiento de equipos mediante solicitudes ARP en la red local.

-sV realiza un escaneo de todos sus puertos TCP para identificar los servicios disponibles y sus versiones

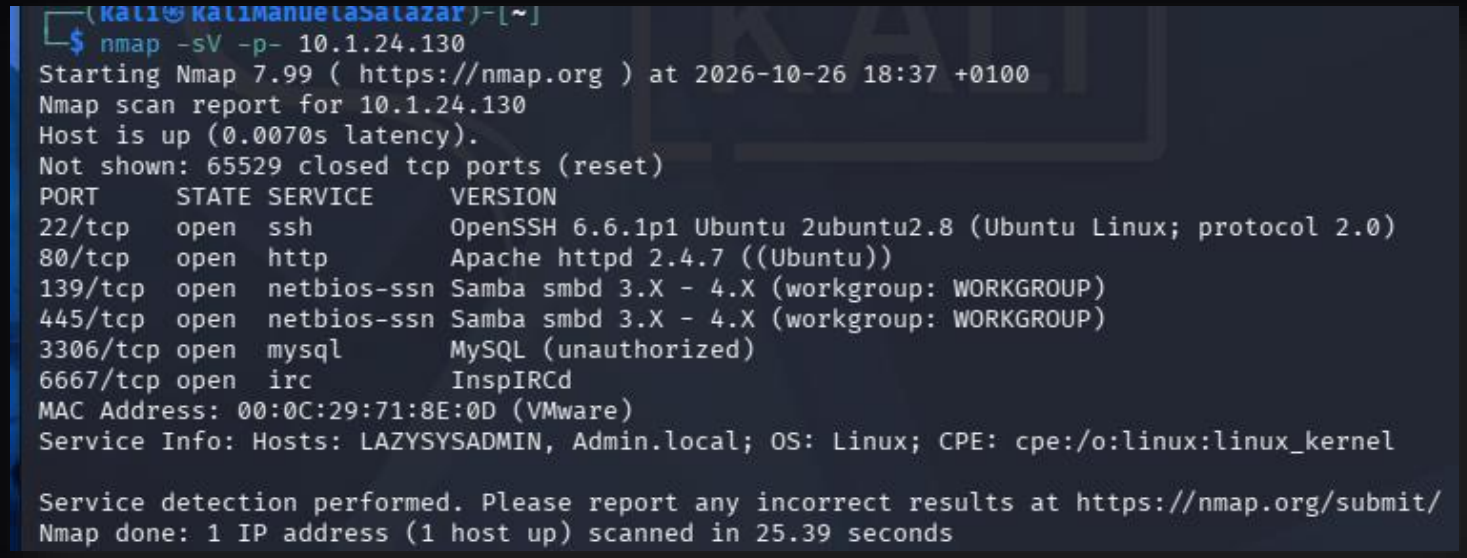


# Enumeración de puertos y servicios

**Objetivo:** identificar los servicios expuestos por la máquina objetivo y determinar qué posibles puntos de entrada debían investigarse.

**Comando utilizado:** nmap -sV -p- 10.1.24.130

Exponemos puertos, servicios y versiones.




**Resultados:**

El escaneo permitió identificar varios servicios abiertos, entre ellos:

| Puerto | Servicio identificado | Interés para la evaluación |
|---|---|---|
| 22/tcp | SSH | Posible acceso remoto |
| 80/tcp | HTTP | Aplicación web y WordPress |
| 139/tcp | NetBIOS / SMB | Enumeración de recursos compartidos |
| 445/tcp | SMB | Acceso a archivos compartidos |
| 3306/tcp | MySQL | Servicio de base de datos |

# Búsqueda de información sensible

**Objetivo:** comprobar si el servicio SMB permitía acceder a recursos compartidos y localizar información que pudiera facilitar el acceso al sistema.

**Comando utilizado:** smbclient -L //10.1.24.130

Realizamos una inspección de archivos donde tenemos deets.txt y todolist.txt que posteriormente son accedidos con el comando cat

**Resultado:** obtuvimos información sensible almacenada en texto plano que permitió orientar las siguientes pruebas hacia WordPress y la posible reutilización de credenciales.

```
┌──(kali㉿kaliManuelaSalazar)-[~]
└─$ smbclient -L //10.1.24.130 -N

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        share$          Disk      Sumshare
        IPC$            IPC       IPC Service (Web server)
Reconnecting with SMB1 for workgroup listing.

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            LAZYSYSADMIN
```

```
┌──(kali㉿kaliManuelaSalazar)-[~]
└─$ cat deets.txt
CBF Remembering all these passwords.

Remember to remove this file and update your password after we push out the server.

Password 12345

┌──(kali㉿kaliManuelaSalazar)-[~]
└─$ cat todolist.txt
Prevent users from being able to view to web root using the local file browser

┌──(kali㉿kaliManuelaSalazar)-[~]
└─$
```

# Análisis de WordPress y pruebas de explotación

**Objetivo:** analizar la información de configuración de WordPress y comprobar si las credenciales encontradas permitían acceder a la aplicación.

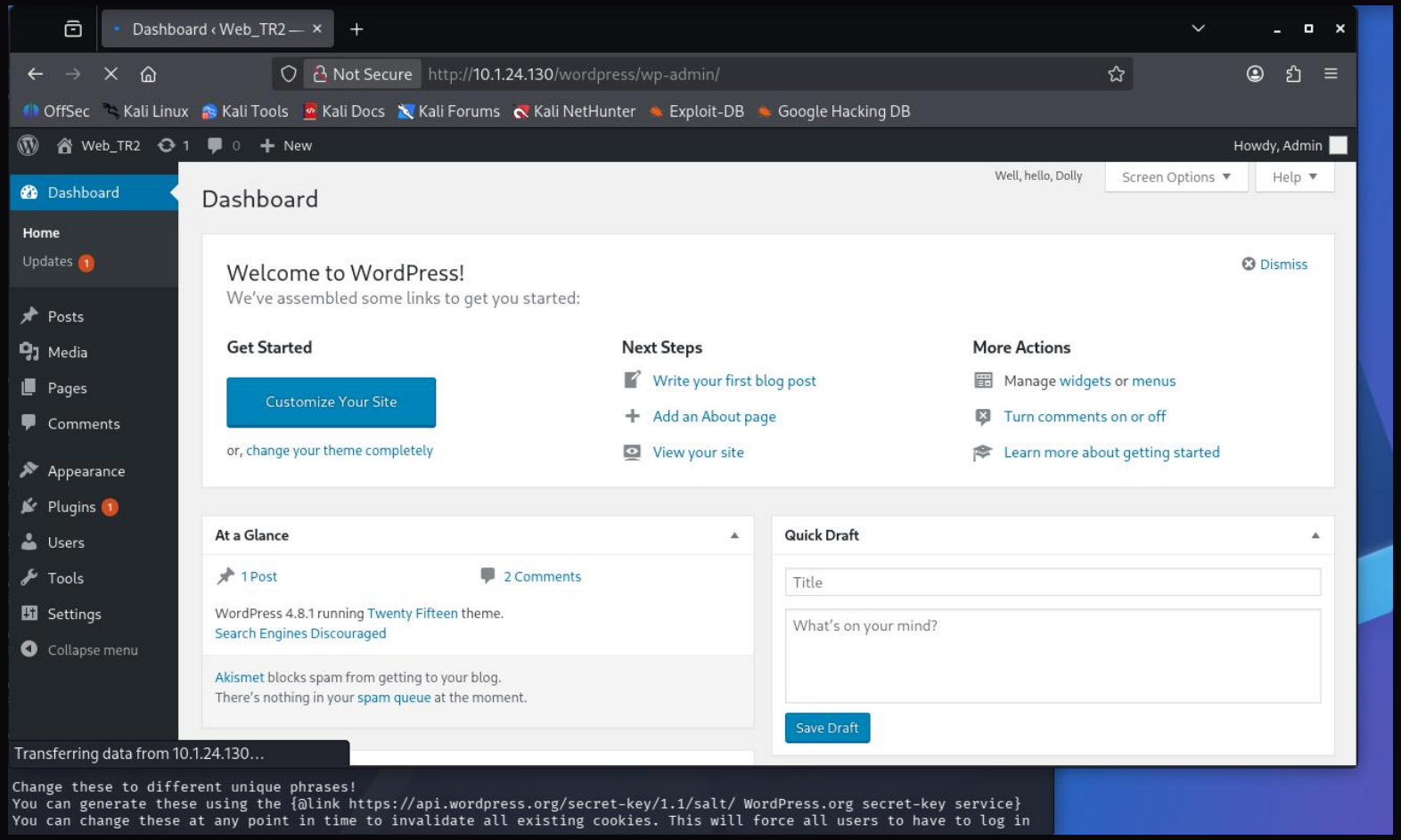
Comandos usados:

1. cd wordpress
2. get wp-config.php
3. cat wp-config.php

### Identificación de información sensible

El archivo wp-config.php contenía parámetros de conexión a la base de datos, entre ellos:

1. Nombre de la base de datos.
2. Usuario de conexión.
3. Contraseña de la base de datos.
4. Dirección del servidor de base de datos.



# Acceso SSH y escalada de privilegios

**Objetivo:** comprobar si las credenciales obtenidas permitían acceder al sistema operativo y evaluar los privilegios de la cuenta conseguida.

**Acceso remoto mediante SSH:** ssh togie@10.1.24.130

**Privilegios:** comprobamos las operaciones permitidas con sudo –l  y los escalamos con sudo su, consiguiendo con esto acceder al archivo de pruebas /root/proof.txt

La evaluación confirmó que la combinación de información sensible expuesta, credenciales reutilizables y permisos excesivos permitió comprometer completamente la máquina.

